TLP:CLEAR Unrestricted public release.

CYBER THREAT INTELLIGENCE REPORT

Linux kernel TCP use-after-free (CVE-2026-98432) rated 9.8, with Ubuntu and RHEL fixes unconfirmed

From **Cybersecurity Briefing** · 2026-10-29 to 2026-11-03 · Briefing generated 2026-11-03

REPORT ID	VERSION	HANDLING
CTI-20261103-01	1.0 · 2026-11-03 08:45 EST	TLP:CLEAR
BRIEFING SECTION	**ORIGINAL PUBLISHED**	**LAST UPDATE**
	2026-10-29	2026-11-03
CVES	**ANALYST**	
CVE-2026-98432 (CVSS 9.8)	Nick Sturgeon	

VULNERABILITY **CRITICAL**

FIXES AVAILABLE FOR MOST DISTRIBUTIONS; UBUNTU LTS FIXES STILL IN -PROPOSED TESTING; NO IN-THE-WILD EXPLOITATION REPORTED

OVERALL CONFIDENCE: MODERATE

BOTTOM LINE UP FRONT

CVE-2026-98432 is a race condition that causes a use-after-free in the Linux kernel's IPv4 TCP connection setup. When a handshake completes, the kernel hands IP options from the pending request to the new socket without copying them. A retransmitted SYN handled on another CPU can then read those options after they are freed [S3]. Kernels from 4.4 onward are affected, an attacker needs no credentials, and the kernel CVE team scores it 9.8 [S1] [S3]. The race is reached through ordinary listening TCP ports using connection requests that carry IPv4 Record Route or Timestamp options [S2].

The briefing headline is now out of date. Red Hat shipped kernels for RHEL 8, 9 and 10 on 2026-11-01 and raised its rating to Critical 9.8, replacing the earlier 5.9 and 8.1 scores [S2] [S4] [S6]. RHEL 9 kernel-rt and the OpenShift CoreOS images are still listed as affected [S4]. Ubuntu remains unfixed in its regular update channel: 22.04, 24.04 and 26.04 fixes are in the opt-in -proposed pocket with no release date, and 16.04, 18.04 and 20.04 fixes are pending [S7] [S8]. Debian, AlmaLinux, Oracle and Amazon Linux have fixes, and SUSE has fixes for many products but not yet all [S15] [S16] [S17] [S18] [S19]. Ubuntu kernel notices dated 2026-11-03 should not be mistaken for this fix, because the builds reviewed are older than the fix builds Canonical names [S7] [S9] [S10].

No vendor, CERT or the kernel CVE team has reported attacks, and the CVE was absent from the CISA KEV catalog version 2026.10.30 [S2] [S25]. Its EPSS score is low at 0.00457 [S24]. Those signals should not be overread. Anthropic reports a working remote root exploit against servers with a Multipath TCP (MPTCP) listener, taking about 53 minutes in its test, but has not published the code and no independent reproduction has been found [S11] [S21] [S22]. The Hacker News also reports public proof-only code that triggers the race and detects leaked memory but does not achieve code execution, while Canonical knows of no other generated or published exploit, so this point is unresolved [S2] [S7]. Whether code execution is possible without an MPTCP listener is unknown; the Go team warns such systems may be vulnerable to similar attacks [S12] [S13].

Install the vendor's fixed kernel and reboot, starting with internet-facing and untrusted-network hosts. Where no fix exists, apply Red Hat's nftables rule that drops inbound IPv4 TCP packets with IP options, limit network exposure, and inventory MPTCP listeners, including those opened by Go 1.24 or later programs [S5] [S12] [S15] [S20]. Disabling MPTCP alone does not address the underlying bug, and Canonical regards security updates as the only appropriate mitigation [S7] [S14].

Key judgments

LIKELY · MODERATE CONFIDENCE

Canonical will likely move the 22.04, 24.04 and 26.04 fixes from -proposed to the regular updates pocket within 7 days of this report. Builds are already in qualification testing, though Canonical has given no date and a test failure could delay release. [S2] [S7] [S8]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE

There is a roughly even chance that a public exploit achieving code execution against MPTCP listeners appears within 30 days. The fix commits, Anthropic's two-stage description and reported trigger-only code all reduce the effort, but the exploit details and target configuration remain unpublished. [S2] [S3] [S11] [S21]

UNLIKELY · MODERATE CONFIDENCE

Mass, internet-scale remote code execution using this flaw is unlikely within 30 days. Anthropic's test took close to an hour against one target, reliable execution needs precise heap control, and the demonstrated path needs an MPTCP listener that some distributions do not enable by default. Targeted attacks against high-value unpatched hosts are a more plausible first use, and that assessment would change quickly if weaponized code were published. [S4] [S11] [S13] [S15]

ROUGHLY EVEN CHANCE · LOW CONFIDENCE

There is a roughly even chance that researchers demonstrate code execution without an MPTCP listener within 90 days. The bug is in plain IPv4 TCP, and Red Hat rates remote code execution as reachable, but no public source explains why Anthropic's chain depends on MPTCP or shows a path without it. [S5] [S11] [S12] [S13] [S14]

INDICATORS OF COMPROMISE

No IP addresses, domains, hashes or other atomic indicators have been published, and the observed-attack record is empty as of 2026-11-03 [S2] [S22]. The entries below are packet patterns, crash strings and exposure conditions from vendor and research sources; exposure entries show that a host is at risk, not that it was compromised.

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Inbound IPv4 TCP SYN carrying a Record Route or Timestamp IP option, followed by a retransmitted SYN`	Known race trigger. Timing must overlap the connection setup, and a lost race only fails that handshake, so repeated attempts are expected. This is the IP-header Timestamp option, not the common TCP-header timestamp.	REPORTED		[S1] [S2] [S21]
port	`Any listening TCP port (IPv4)`	No specific service or port is required for the race. Anthropic's code execution demonstration specifically targeted an MPTCP listener.	REPORTED		[S2] [S11]
other	`SYN-ACK from a server echoing freed or extra kernel memory bytes in its IP options`	Anthropic's first stage makes the kernel return extra bytes, and the reported proof-only code detects freed memory echoed in a SYN-ACK.	REPORTED		[S2] [S11]
other	`ip_options_build`	Function named in the CVE record as the use-after-free site. Rescana advises investigating crash or oops reports naming it on internet-facing hosts.	REPORTED		[S3] [S22]
other	`ip_build_and_send_pkt`	Kernel crash or oops string suggested for investigation on internet-facing hosts. Single secondary source.	REPORTED		[S22]
other	`skb_under_panic`	Kernel crash string suggested for investigation on internet-facing hosts. Single secondary source; this panic can also have unrelated causes.	REPORTED		[S22]
command	`ip protocol tcp ip hdrlength > 5 counter drop`	Defensive rule from Red Hat's bulletin. A rising counter shows inbound TCP packets with IP options reached the host; it does not prove an exploit attempt.	REPORTED		[S5]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
command	`ss -lnMp`	Exposure check. Lists MPTCP listeners and their owning processes. Requires an iproute2 version that supports -M.	REPORTED		[S15] [S21]
other	`net.mptcp.enabled=1`	Exposure condition. Applications can open MPTCP sockets. AlmaLinux and TuxCare report this is off by default on Enterprise Linux 8, 9 and 10; verify on each host.	REPORTED		[S15] [S21]
other	`net.ipv4.tcp_migrate_req=1`	Exposure condition. Enables the secondary request-socket migration path, which is off by default.	REPORTED		[S21]
other	`BPF_SK_REUSEPORT_SELECT_OR_MIGRATE`	Exposure condition. An attached eBPF program of this type also enables the migration path.	REPORTED		[S21] [S22]
other	`Go 1.24 or later listener with GODEBUG multipathtcp not set to 0, or code calling SetMultipathTCP`	Exposure condition. Go enables MPTCP on Linux listening sockets by default from 1.24, so a service may expose MPTCP without administrators knowing.	REPORTED		[S12] [S20]
command	`tcpdump -ni any 'ip and tcp[tcpflags] & tcp-syn != 0 and (ip[0] & 0x0f) > 5'`	Hunting filter built from the reported trigger. An IPv4 header length above 5 words means IP options are present, the same test used by the vendor nftables rules. It also matches SYN-ACKs carrying options.	DERIVED		[S2] [S5]
other	`Sustained IP-option SYNs and failed handshakes from one source to one port over tens of minutes`	Inferred from Anthropic's 48-minute leak phase and its statement that a lost race only fails the handshake. The real rate is unknown, and an attacker could distribute or slow the traffic.	DERIVED		[S11]

Type	Indicator (defanged)	Context	Provenance	First seen	Source
other	`Shell process running as root with a kernel thread (kworker or kthreadd) as its parent`	Inferred because Anthropic's payload chains kernel functions to run a shell command as root, which would likely start outside any normal service process tree. The exact mechanism is unpublished and kernel helpers can create benign matches, so treat this as low fidelity.	DERIVED		[S11]

Indicators are defanged (hxxp, [.], [@]) so they cannot be clicked. "Reported" means stated in a source; "Derived" means inferred by the analyst from the source material and should be validated before blocking.

TACTICS, TECHNIQUES & PROCEDURES (TTPS)

An unauthenticated attacker sends IPv4 TCP connection requests with IP options to a listening port and retransmits them to race socket teardown on another CPU. Winning the race causes the kernel to read freed IP options [S3]. In Anthropic's lab chain against an MPTCP listener, the first stage makes the kernel use an attacker-controlled length and return extra memory, and a leaked kernel pointer defeats KASLR. The second stage uses the same bug to overflow a buffer and overwrite a callback pointer, redirecting execution to a payload already placed in kernel memory through a normal protocol feature. The payload then chains kernel functions to run a shell command as root. Lost races only fail the handshake, so the attacker can retry [S11]. This chain is single-sourced, has not been reproduced publicly and has not been observed in attacks [S2] [S21].

MITRE ATT&CK mapping

Tactic	Technique	Procedure observed	Detection opportunity
Initial Access	T1190 Exploit Public-Facing Application	Lab demonstration: remote exploitation of the kernel TCP stack through an exposed MPTCP listener, with no credentials or user interaction. [S2] [S11]	Alert on inbound SYNs with IP options, especially repeated attempts, and on crash strings naming ip_options_build.
Defense Evasion	T1211 Exploitation for Defense Evasion	Lab demonstration: a memory overread returns a kernel pointer that defeats KASLR, after about 48 minutes in Anthropic's test. [S11]	Inspect outbound SYN-ACKs for unexpected IP options on services that normally send none.
Privilege Escalation	T1068 Exploitation for Privilege Escalation	Lab demonstration: a buffer overflow overwrites a callback pointer and redirects kernel execution to a staged payload, reaching root without prior host access. [S11] [S22]	Review kernel oops and panic logs. Lost races may leave no crash, so quiet logs do not clear a host.

Tactic	Technique	Procedure observed	Detection opportunity
Execution	T1059.004 Command and Scripting Interpreter: Unix Shell	Lab demonstration: the kernel payload ends by running an attacker-chosen shell command as root. [S11]	Hunt for root shells with kernel-thread parents, followed by unexpected network connections, accounts or persistence.
Impact	T1499.004 Endpoint Denial of Service: Application or System Exploitation	Red Hat cites memory corruption or a system crash as an outcome of remote IPv4 TCP traffic; this is a capability, with no reported attack. [S4]	Correlate unplanned reboots and kernel panics on exposed hosts with inbound IP-option traffic.

Detection & hunting

Queries are built from the reported behavior and indicators. They are untested; tune field names for your environment.

IPv4 options on TCP handshakes `SURICATA`

```
alert tcp any any -> $HOME_NET any (msg:"Possible CVE-2026-98432 probing - SYN with IPv4 Record Route option"; flags:S,CE; ipopts:rr; threshold:type both, track by_src, count 5, seconds 60; classtype:attempted-admin; sid:9098432; rev:1;)
alert tcp any any -> $HOME_NET any (msg:"Possible CVE-2026-98432 probing - SYN with IPv4 Timestamp option"; flags:S,CE; ipopts:ts; threshold:type both, track by_src, count 5, seconds 60; classtype:attempted-admin; sid:9098433; rev:1;)
alert tcp $HOME_NET any -> any any (msg:"Server SYN-ACK carrying IPv4 options - review for CVE-2026-98432"; flags:SA,CE; ipopts:any; threshold:type limit, track by_src, count 1, seconds 300; classtype:misc-activity; sid:9098434; rev:1;)
```

Sensor must see traffic before any filter that strips or drops IP options. These rules detect the trigger pattern or a suspicious response, not successful exploitation. Tune thresholds locally. Option-bearing legacy or diagnostic traffic can cause false positives.

Kernel crash strings on Linux hosts `SPLUNK SPL`

```
index=* (sourcetype=syslog OR sourcetype=linux_messages_syslog OR sourcetype=journald)
("ip_options_build" OR "ip_build_and_send_pkt" OR "skb_under_panic")
| stats count min(_time) AS first_seen max(_time) AS last_seen BY host
| convert ctime(first_seen) ctime(last_seen)
| sort - count
```

Adjust the index and sourcetypes. A hit needs triage, and no hit does not clear a host because a lost race does not crash it. Preserve any crash dump before patching.

Kernel crash strings in Microsoft Sentinel `KQL`

```
Syslog
| where TimeGenerated > ago(30d)
| where Facility == "kern"
| where SyslogMessage has_any ("ip_options_build", "ip_build_and_send_pkt", "skb_under_panic")
| summarize Hits = count(), FirstSeen = min(TimeGenerated), LastSeen = max(TimeGenerated) by Computer
| order by Hits desc
```

Requires kernel facility logging to reach the workspace. Same interpretation limits as the SPL query.

Root shell started by a kernel thread `KQL`

```
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("sh", "bash", "dash", "ash")
| where AccountName == "root"
| where InitiatingProcessFileName startswith "kworker" or InitiatingProcessFileName == "kthreadd"
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessFileName,
InitiatingProcessId
| order by Timestamp desc
```

Low-fidelity hunt based on an inference, because the exact execution mechanism is unpublished. Kernel helpers can produce benign matches, and EDR agents may report parent details differently. Baseline first and review command lines.

REMEDIATION ACTIONS

Exposure

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Linux kernel (upstream)	4.4 and later, before the fixed stable releases	5.10.272, 5.15.223, 6.1.190, 6.6.159, 6.12.113, 6.18.56, 7.2.10, 7.3	CVE-2026-98432	9.8 (kernel CNA)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
Red Hat Enterprise Linux 8, 9, 10	Earlier kernels; RHEL 6 and 7 not affected	RHEL 8.10: 4.18.0-553.182.1.el8_10 (RHSA-2026:93414); RHEL 8 RT: kernel-rt-4.18.0-553.182.1.rt7.523.el8_10 (RHSA-2026:93415); RHEL 9.8: 5.14.0-687.64.1.el9_8 (RHSA-2026:93412); RHEL 10.2: 6.12.0-211.72.1.el10_2 (RHSA-2026:93413); RHEL 9.4 SAP: 5.14.0-427.161.1.el9_4 (RHSA-2026:94109); RHEL 8.8 TUS and SAP: 4.18.0-477.178.1.el8_8 (RHSA-2026:94303). RHEL for NVIDIA 10: 6.12.0-265.31.el10nv (RHSA-2026:93775)	CVE-2026-98432	9.8 (Red Hat)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
RHEL 9 kernel-rt; OpenShift 4 and 5 CoreOS images	Listed as Affected on 2026-11-03	No fixed release listed	CVE-2026-98432	9.8 (Red Hat)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
Ubuntu 22.04, 24.04, 26.04 LTS	Regular updates pocket remains vulnerable	-proposed only: 22.04 5.15.0-203.213; 24.04 6.8.0-149.149; 26.04 7.0.0-43.43. Other flavors have separate builds listed as work in progress	CVE-2026-98432	9.8	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
Ubuntu 26.10	Sources conflict on status	Canonical's blog says fixed in 7.3.0-10.10; the CVE page still says work in progress in that build	CVE-2026-98432	9.8	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
Ubuntu 16.04, 18.04, 20.04	Vulnerable	Fix pending; 14.04 not affected	CVE-2026-98432	9.8	0.00457 (39.6th percentile, 2026-11-02)	No	N/A

Product	Affected	Fixed in	CVE	CVSS	EPSS	CISA KEV	KEV due date
AlmaLinux 8, 9, 10	Earlier kernels	4.18.0-553.182.1.el8_10; 5.14.0-687.64.1.el9_8; 6.12.0-211.72.1.el10_2	CVE-2026-98432	9.8 (cited from kernel CNA)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
Oracle Linux 7 to 10	Earlier kernel and kernel-uek packages	kernel: ELSA-2026-93412 (OL9), ELSA-2026-93413 (OL10), ELSA-2026-93414 (OL8), all 2026-11-02. UEK advisories: 2026-10-16 and 2026-11-02; use the latest for the release	CVE-2026-98432	8.1 (Oracle, preliminary)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
Debian 12 and 13	Base-release kernels	bookworm linux 6.1.190-1 (DLA-4841-1); bookworm linux-6.12 6.12.113-1~deb12u1 (DLA-4850-1); trixie linux 6.12.113-1 (DSA-6568-1)	CVE-2026-98432	9.8 (kernel CNA)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
Amazon Linux 2 and 2023	Earlier kernels	AL2: ALAS2-2026-4065 and kernel extras advisories (2026-10-30). AL2023: kernel ALAS2023-2026-3365 (2026-10-30), kernel6.12 ALAS2023-2026-3335 (2026-10-29), kernel6.18 ALAS2023-2026-3251 (2026-10-24)	CVE-2026-98432	8.1 (Amazon)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A
SUSE Linux Enterprise and openSUSE	Mixed. SLES 15 SP7 and SLES 12 SP5 LTSS shown in progress; SLE Micro 6.0 and 6.1 still have affected or in-progress packages	Released for SLES 16.0, SLES 15 SP4 to SP6 LTSS, SLE Micro 5.4, 5.5 and 6.2, and openSUSE Leap 16.0 among others. See SUSE's per-product table	CVE-2026-98432	8.1 v3.1 and 9.2 v4.0 (SUSE)	0.00457 (39.6th percentile, 2026-11-02)	No	N/A

Immediate (0–24 hours)

- Build a Linux asset list from patch and RMM tools, record each running kernel with uname -r, and rank internet-facing and untrusted-network hosts first. Compare against vendor advisories, because backported fixes may not be visible in the version string. `IT OPS` [S21]
- On RHEL, AlmaLinux, Oracle, Debian, Amazon Linux and fixed SUSE products, install the vendor kernel listed in the exposure table and reboot. Confirm with uname -r that the fixed kernel is the one running. `IT OPS` [S4] [S6] [S15] [S16] [S17] [S18] [S19]
- Do not treat Ubuntu kernel USNs dated 2026-11-03 as the fix. USN-8959-1 does not list this CVE in the portion reviewed and ships 7.0.0-42.42, and USN-8961-1 ships 5.15.0-202.212 for 22.04, both below Canonical's fix builds. Verify against Canonical's CVE page. `IT OPS` [S7] [S8] [S9] [S10]
- On hosts without a fix, test and then apply Red Hat's nftables rule dropping inbound IPv4 TCP with IP options. Treat it as partial, confirm that it persists if a reboot is planned, and watch its counter. `IT OPS` [S5] [S15]
- Inventory MPTCP listeners with ss -lnMp on Linux hosts and record net.mptcp.enabled and net.ipv4.tcp_migrate_req. Investigate any MPTCP listener on an exposed port first. `SOC` [S15] [S21]
- Search retained kernel logs for the crash strings and enable the network and log detections in this report. Quiet results do not clear a host. `SOC` [S22]

Short term (1–7 days)

- Install Ubuntu fixes from the regular updates pocket as soon as Canonical releases them, and reboot. Check its blog and CVE page daily, including separate status for cloud, FIPS and real-time flavors. `IT OPS` [S7] [S8]
- Decide whether exposed Ubuntu hosts should use the -proposed kernels before general release. Test first, because -proposed is an opt-in testing channel still in qualification, and approve it as a documented risk decision. `LEADERSHIP` [S2] [S7]
- Track RHEL 9 kernel-rt and OpenShift CoreOS fixes. Update OpenShift nodes through their supported process once images are listed, and do not assume node rules protect pod-to-pod traffic. `IT OPS` [S4] [S5]
- Identify Go 1.24 or later services on Linux. Where a fix is delayed, set GODEBUG=multipathtcp=0 or disable MPTCP system-wide when it is not needed, then restart those services. Check for code using SetMultipathTCP, which overrides the setting. `IT OPS` [S12] [S15] [S21]
- Ask vendors of Linux-based appliances, hypervisors and managed cloud images for written CVE-2026-98432 status, and record any hosts that cannot be patched. Containers share the host kernel, so patch hosts rather than relying on image rebuilds. `IT OPS` [S3] [S5]
- Report remaining unpatched exposed hosts, compensating controls and any exceptions to leadership until closure. `LEADERSHIP` [S2] [S7]

Long term

- Keep an inventory of kernel versions, distribution support status and network exposure across all client environments. Replace or buy extended support for releases that receive fixes late, such as older Ubuntu versions. `LEADERSHIP` [S2] [S7]
- Set kernel patch service levels on vendor priority and exposure, not on one CVSS value. This CVE moved through 5.9, 8.1 and 9.8 at one vendor in days. `LEADERSHIP` [S1] [S4]

- Plan and test rapid reboot or supported live-patch processes for critical Linux systems, because every listed kernel fix needs either a reboot or a separate live patch. `IT OPS` [S6] [S7] [S21]
- Add MPTCP listener state and non-default kernel network settings to routine configuration audits, because applications and eBPF can enable MPTCP without an obvious service setting. `SOC` [S12] [S23]

Workarounds & compensating controls

- Restrict TCP services on unfixed hosts to trusted networks or IP addresses wherever business needs allow. `IT OPS` [S20]
- Drop inbound IPv4 TCP packets with IP options on hosts, and verify whether perimeter firewalls also drop them. Host rules may miss same-host container traffic and do not cover CIPSO or NetLabel setups, so this reduces but does not eliminate risk. `IT OPS` [S5] [S13] [S14] [S15]
- Disable MPTCP with net.mptcp.enabled=0 where it is not needed, and restart services with existing listeners. This addresses the demonstrated path only, not the IPv4 TCP bug, and can break programs that require MPTCP. `IT OPS` [S7] [S14] [S15]
- Keep net.ipv4.tcp_migrate_req at 0 and confirm no reuseport migration eBPF program is attached. `IT OPS` [S21] [S22]
- Do not rely on init_on_free=1 as a mitigation. It was proposed on oss-security and then rebutted by a CIQ kernel engineer because the KASLR defeat can read live objects. `SOC` [S14]

Actions marked with an owner: SOC = security operations, IT Ops = system and network administration, Leadership = risk and communications decisions.

SOURCES

[S1] The Hacker News: Linux Kernel TCP Flaw With 9.8 CVSS Score Affects Ubuntu, Red Hat and Other Distributions
Published 2026-10-29 · `B2` Usually reliable, probably true
Briefing source, updated 2026-10-30. Its Red Hat and Ubuntu status is superseded.

[S2] The Hacker News: Red Hat Patches 9.8-Rated Linux TCP RCE Flaw While Ubuntu Releases Fixes for Testing
Published 2026-11-03 · `B2` Usually reliable, probably true
Newest press summary. Sole source opened for the public proof-only code; that code was not visited.

[S3] CVE Program / Linux kernel CNA: CVE-2026-98432 record
Published 2026-10-15 · `A1` Completely reliable, confirmed by other sources
Primary record: description, versions, fix commits and 9.8 score.

[S4] Red Hat: Security Data API: CVE-2026-98432
Published 2026-10-15 · **A1** Completely reliable, confirmed by other sources
Primary. Rating, advisories and package state, read 2026-11-03.

[S5] Red Hat: RHSB-2026-016 security bulletin
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Primary. Updated 2026-11-02; status ongoing. Partial nftables mitigation.

[S6] Red Hat: RHSA-2026:93412 kernel security, bug fix, and enhancement update
Published 2026-11-01 · **A1** Completely reliable, confirmed by other sources
Primary. Confirms the RHEL 9 fix. The advisory carries an Important aggregate severity.

[S7] Canonical: Fixes available in -proposed pocket for CVE-2026-98432
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Primary vendor statement on Ubuntu fix status and mitigation.

[S8] Canonical: Ubuntu CVE-2026-98432 tracker
Published 2026-10-15 · **A1** Completely reliable, confirmed by other sources
Primary. Updated 2026-11-03; lists no USN. Its nftables workaround is community-submitted.

[S9] Canonical: USN-8959-1: Linux kernel vulnerabilities
Published 2026-11-03 · **A2** Completely reliable, probably true
Primary. CVE not in the reference list reviewed; the page was only partly read.

[S10] Canonical: USN-8961-1: Linux kernel vulnerabilities
Published 2026-11-03 · **A2** Completely reliable, probably true
Primary. CVE not visible, but part of the reference list was collapsed. Generic build is below the fix build.

[S11] Anthropic: Discovering vulnerabilities with Claude
Published 2026-10-27 · **A3** Completely reliable, possibly true
Original researcher. The exploit claim is not independently reproduced, and the publisher has a commercial interest.

[S12] Go Security Team via oss-security: Protecting against CVE-2026-98432 when using Go programs
Published 2026-10-29 · **A2** Completely reliable, probably true
Primary guidance for Go. Forwarded to oss-security by Alan Coopersmith.

[S13] Go project: proposal: net: Disable MPTCP by default (issue 82717)
Published 2026-10-29 · **B3** Usually reliable, possibly true
Open discussion among maintainers and contributors, with no decision. Comments are opinion as well as fact.

[S14] oss-security (Sultan Alsawaf, CIQ): Reply on init_on_free=1 and CVE-2026-98432
Published 2026-11-02 · **B3** Usually reliable, possibly true
Practitioner analysis, partly inferred from code and attributed by its author to a Claude model. Replies to a proposal by Rui Sousa.

[S15] AlmaLinux: CVE-2026-98432: Patched kernels released
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Primary. Updated 2026-11-02.

[S16] Amazon Linux: ALAS CVE-2026-98432
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Primary. Date shown is the latest listed advisory.

[S17] Debian: Security Tracker: CVE-2026-98432
Published · **A1** Completely reliable, confirmed by other sources
Primary. Living tracker with no publication date shown.

[S18] SUSE: SUSE CVE-2026-98432
Published 2026-10-15 · **A1** Completely reliable, confirmed by other sources
Primary. Last modified 2026-11-03.

[S19] Oracle Linux: CVE-2026-98432
Published 2026-11-02 · **A1** Completely reliable, confirmed by other sources
Primary. Date shown is the latest listed advisory. CVSS is preliminary.

[S20] BleepingComputer: Critical Linux kernel flaw allows remote root attacks on MPTCP servers
Published 2026-10-30 · **B2** Usually reliable, probably true
Press report carrying CIQ's mitigation view. Patch status is superseded.

[S21] TuxCare: CVE-2026-98432 Linux Kernel TCP Flaw, Claude's Claimed Root Exploit and Which Distros Are Patched
Published 2026-10-30 · **B2** Usually reliable, probably true
Vendor blog with a commercial interest. Useful checks; patch status is superseded.

[S22] Rescana: Linux Kernel CVE-2026-98432: Critical TCP Use-After-Free, RHEL Fixed, Ubuntu Pending
Published 2026-11-02 · **C3** Fairly reliable, possibly true
Smaller vendor. Sole source for two crash strings and the 2026-11-02 KEV check.

[S23] CSO Online: Anthropic AI model finds Linux kernel bug that leads to remote root access
Published 2026-10-30 · **B2** Usually reliable, probably true
Press report. Quotes no independent experts.

[S24] FIRST: EPSS API result for CVE-2026-98432
Published 2026-11-02 · **A2** Completely reliable, probably true
Model output, not evidence about exploitation.

[S25] CISA: Known Exploited Vulnerabilities catalog, version 2026.10.30
Published 2026-10-30 · **A1** Completely reliable, confirmed by other sources
Reviewed the newest-first entries back to 2026-09-16, which predates the CVE; CVE absent.

Grades use the Admiralty scale: letter = source reliability (A completely reliable to F cannot be judged), number = information credibility (1 confirmed to 6 cannot be judged).

MISCELLANEOUS

Timeline

Date	Event	Source
2026-09-25	CVE ID reserved.	[S3]
2026-10-05	Upstream fix applied, as reported by The Hacker News. The kernel commit page could not be opened to confirm the date.	[S1]
2026-10-15	CVE-2026-98432 published.	[S3]
2026-10-16	Oracle UEK advisories released; Debian trixie fix follows around this date.	[S1] [S19]
2026-10-24	Kernel CNA adds the 9.8 score. Amazon ships the AL2023 kernel6.18 fix.	[S3] [S16]
2026-10-27	Anthropic publishes its exploit description.	[S11]
2026-10-29	The Hacker News publishes the briefing story. The Go Security Team issues guidance and SUSE releases advisories.	[S1] [S12] [S18]
2026-10-30	Red Hat publishes RHSB-2026-016 with its partial mitigation. Amazon completes its listed fixes. AlmaLinux posts its advisory. The CISA KEV version reviewed does not include the CVE.	[S5] [S15] [S16] [S25]
2026-11-01	Red Hat ships RHEL 8, 9 and 10 kernel fixes.	[S4] [S6]

Date	Event	Source
2026-11-02	Canonical places 22.04, 24.04 and 26.04 fixes in -proposed. Oracle releases more advisories. AlmaLinux updates its advisory for production fixes. A CIQ engineer rebuts init_on_free=1 as a mitigation.	[S7] [S14] [S15] [S19]
2026-11-03	Red Hat adds more extended-support fixes, and The Hacker News reports the current patch state. Ubuntu's tracker still lists regular LTS kernels as vulnerable.	[S2] [S4] [S8]

Relevance to Indianapolis, Indiana & managed clients

No source reports Indianapolis or Indiana victims or targeting. Exposure comes from technology in use: Linux web, application, database and file servers, cloud workloads, container hosts and vendor appliances. Indiana hospitals and clinics should prioritize exposed portals and ask medical and imaging vendors about embedded Linux status before changing anything regulated. State and local government and schools should check public websites, learning platforms and older servers, especially Ubuntu 20.04 or earlier, where fixes are pending and extended support may be required. Manufacturers should check remote-access gateways, plant-floor Linux systems and appliances, where reboots need planned downtime. Small and mid-size businesses may not know they run Linux, so hosted servers and network devices need a provider check. For managed IT clients, the priority is a cross-client kernel inventory, Ubuntu tracking, documented risk decisions where fixes are not yet available, and written appliance vendor responses. Because crashes are possible, change windows should include rollback plans and client notice.

Intelligence gaps

- Whether code execution is possible without an MPTCP listener, and how much the MPTCP dependence constrains real attacks.
- Anthropic's exploit code, kernel version, test setup and reliability across builds, architectures and hardening settings remain unpublished, and no independent reproduction was found.
- Whether the public proof-only code described in [S2] is authentic and how widely it works. Canonical said on 2026-11-02 it knew of no other generated or published exploit.
- Whether IP options reach targets across typical internet paths. A Go issue participant says they are often blocked, but no measurement was found.
- Release date for Ubuntu fixes, timing for 16.04, 18.04 and 20.04, and the correct status for 26.10, where Canonical's blog and tracker differ.
- Fix dates for RHEL 9 kernel-rt and OpenShift CoreOS images, and how other RHEL extended-support streams are covered.
- Rocky Linux and other RHEL rebuild status. BleepingComputer listed Rocky as affected on 2026-10-30, and no Rocky advisory for this CVE was found.
- Status of Linux-based appliances, embedded devices and managed cloud images. No general list was found.
- The separate IPv6 request-socket migration issue noted in the kernel description is to be handled in a different patch, per Debian's tracker; its status was not confirmed.
- NVD status and CWE. The NVD page could not be read, and the CVE record gives no CWE.
- The primary kernel commit and kernel CVE team announcement could not be opened, so commit details rely on the CVE record and other sources.

- CISA KEV status after catalog version 2026.10.30. Watch KEV, Red Hat, Canonical and GreyNoise-style sensor reporting for a change in exploitation status.

Other notes

- Status correction: the briefing headline and excerpt are superseded. The Hacker News's 2026-11-03 headline about Red Hat fixes is confirmed by Red Hat's own data and advisory [S2] [S4] [S6].
- Scoring: Red Hat now rates this Critical 9.8, up from 5.9 on its page and 8.1 in its advisory data [S1] [S4]. Its fix advisories still show Important as an aggregate rating [S6]. Amazon now shows 8.1 rather than the 7.0 in the briefing, and Oracle shows a preliminary 8.1 [S1] [S16] [S19]. SUSE shows 8.1 for CVSS v3.1 and 9.2 for v4.0 [S18]. The main dispute is attack complexity: low in 9.8 vectors and high in 8.1 vectors.
- Mitigation views differ: Red Hat, AlmaLinux and CIQ describe filtering as a partial or interim step, while Canonical says updates are the only appropriate mitigation [S5] [S7] [S14] [S15] [S20]. The nftables examples also differ by table, hook and match expression, so use the distribution vendor's version and test it [S5] [S15] [S21].
- Fix commit e3f33b0a1d89d738e2b913dab519226eaf76e15b is the mainline fix, and 079096f103faca2dd87342cca6f23d4b34da8871 is listed as introducing the flaw [S3].
- Possible source conflict: the bug and exploit claim come from Anthropic, whose Claude model was also used to help draft this report. Exploit claims are therefore graded on external corroboration and remain marked as unreproduced.
- ATT&CK mappings are analyst judgments applied to a lab demonstration, not observations from attacks.

CTI-20261103-01 v1.0 · Generated 2026-11-03 08:45 EST from public reporting. Drafted with AI assistance and reviewed by Nick Sturgeon. Verify indicators and actions before operational use. Summaries are in the analyst's own words.

Back to the daily briefing.

TLP:CLEAR Unrestricted public release.